

脆弱性診断報告書 2024年度

エグゼクティブサマリ

本報告書は、2024年度上期（2024年4月～9月）に実施した脆弱性診断の結果をまとめたものである。診断業務はNRIセキュアテクノロジーズ株式会社に外部委託し、当行のインターネット公開システム、社内基幹系システム、およびクラウド環境を対象に網羅的な診断を実施した。

【検出結果サマリ】

重大（Critical）：0件

高（High）：2件

中（Medium）：5件

低（Low）：12件

情報（Info）：23件

前年度同期比では高リスク以上の検出件数が3件から2件に減少しており、継続的な改善傾向が確認された。検出された高リスク2件については、診断期間中に緊急対応を実施し、2024年9月末時点で全件改修済みである。中リスク5件についても2024年12月末を期限とした改善計画を策定済みである。

診断対象

本年度の診断対象は以下のとおりである。

【インターネット公開システム（8システム）】

- インターネットバンキング（個人向け）— ibk.example-bank.co.jp
- インターネットバンキング（法人向け）— biz.example-bank.co.jp
- 外部向けAPIゲートウェイ — api.example-bank.co.jp
- コーポレートサイト — www.example-bank.co.jp
- 投信・保険販売サイト — fund.example-bank.co.jp
- ローン申込サイト — loan.example-bank.co.jp
- スマートフォンアプリバックエンド — mobile-api.example-bank.co.jp
- オープンAPI（全銀協準拠）— openapi.example-bank.co.jp

【社内基幹系システム（3システム）】

- 勘定系ホスト接続ミドルウェア（EAI基盤）
- 統合OA基盤（Active Directory / Exchange Online）
- 人事給与システム（COMPANY）

【クラウド環境（2テナント）】

- AWS本番環境（ap-northeast-1）— VPC 3構成、EC2 42台、RDS 8インスタンス
- Azure開発・検証環境 — 仮想ネットワーク2構成、VM 18台

合計13システム・環境に対し、延べ2,847エンドポイントを診断対象とした。

診断手法

以下の3カテゴリの診断手法を組み合わせて実施した。

【1. プラットフォーム診断】

使用ツール: Tenable Nessus Professional 10.7、Qualys VMDR

対象: 全サーバ・ネットワーク機器 (合計187ノード)

実施方法: 認証スキャン (SSH/WinRM) により内部からの詳細診断を実施。

スキャンポリシー: CIS Benchmark準拠カスタムポリシーを適用。

実施日程: 2024年5月13日～5月24日 (業務影響を避け21:00～翌6:00に実施)

【2. Webアプリケーション診断】

使用ツール: OWASP ZAP 2.15.0 (自動スキャン)、Burp Suite Professional 2024.4 (手動診断)

対象: インターネット公関係8システムの全画面遷移・API

実施方法: OWASP Testing Guide v4.2に準拠し、自動スキャン後に手動でのロジック診断を実施。

診断項目: SQLインジェクション、XSS、CSRF、認証・認可不備、セッション管理、

ファイルアップロード、SSRF、XXE、ビジネスロジック脆弱性 等 計68項目

実施日程: 2024年6月3日～7月12日

【3. ペネトレーションテスト】

実施者: NRIセキュア認定ペネトレーションテスター (OSCP/OSCE保有者2名)

シナリオ: (A)外部攻撃者シナリオ (インターネット側からの侵入試行)

(B)内部不正シナリオ (社内ネットワークからの権限昇格試行)

実施日程: 2024年7月22日～8月2日

結果: シナリオ(A)では外部からの直接侵入は不可。シナリオ(B)では一部セグメント間のアクセス制御不備により、開発環境から本番DBへの接続が可能な経路を検出 (中リスクとして報告)。

発見事項:高リスク

【VH-001】Apache Struts 旧バージョン使用 (CVE-2024-53677)

対象: 法人向けインターネットバンキング (biz.example-bank.co.jp)

CVSS v3.1スコア: 8.1 (High)

検出内容: Apache Struts 6.3.0.1 が使用されており、ファイルアップロードロジックにおけるパストラバーサル脆弱性 (CVE-2024-53677) の影響を受ける。攻撃者が細工したリクエストにより、サーバ上の任意のディレクトリにファイルを配置できる可能性がある。

対応状況: 【対応済み】2024年8月9日にStruts 6.4.0へアップデート適用。

WAFルールによる暫定遮断を8月5日に先行適用済み。

再診断: 2024年8月12日に再診断実施、脆弱性が解消されたことを確認。

【VH-002】管理画面へのアクセスIP制限不備

対象: ローン申込サイト管理コンソール (loan.example-bank.co.jp/admin/)

CVSS v3.1スコア: 8.5 (High)

検出内容: 管理画面 (/admin/配下) へのアクセスがインターネットから可能な状態であった。認証機構 (ID/パスワード) は存在するが、ブルートフォース対策 (アカウントロック等) が未実装であり、辞書攻撃による不正ログインのリスクが高い。

対応状況: 【対応済み】2024年8月16日にALBのセキュリティグループを修正し、

管理画面へのアクセスを社内IPレンジ (10.0.0.0/8経由のNAT GW IP) に限定。

追加対応として多要素認証 (TOTP) を2024年9月6日に導入完了。

発見事項:中リスク

【VM-001】 TLS 1.0/1.1 が有効な旧システム

対象: 勘定系ホスト接続ミドルウェア (EAI基盤) の管理ポータル

CVSS v3.1スコア: 5.9 (Medium)

検出内容: TLS 1.0およびTLS 1.1が有効化されたままであり、BEAST攻撃やPOODLE攻撃のリスクがある。PCI DSS v4.0要件 (2025年3月期限) にも抵触する。

改善期限: 2024年12月末 (ホスト側クライアント更新と同時対応予定)

【VM-002】 セッションタイムアウト設定の不統一

対象: 個人向けIB (30分) 、法人向けIB (60分) 、投信サイト (無制限)

CVSS v3.1スコア: 4.8 (Medium)

検出内容:

システムごとにセッションタイムアウト値がばらばらであり、投信・保険販売サイトではタイムアウトが設定されていなかった。FISC安全対策基準

技術基準T29に抵触する可能性がある。

改善期限: 2024年11月末

【VM-003】 CSRF対策トークン未実装箇所

対象: ローン申込サイトの一部POST処理 (4エンドポイント)

CVSS v3.1スコア: 5.4 (Medium)

検出内容: 申込情報変更・キャンセル処理においてCSRFトークンが実装されていなかった。

改善期限: 2024年11月末

【VM-004】 開発環境から本番DBへの接続経路

対象: AWS環境 (開発VPC→本番VPC間のVPCピアリング)

CVSS v3.1スコア: 6.5 (Medium)

検出内容: ペネトレーションテストにより、開発VPCのEC2インスタンスから本番VPCのRDS (PostgreSQL 5432/tcp) への直接接続が可能であることを確認。セキュリティグループの設定不備により、開発環境からの全ポートが許可されていた。

改善期限: 2024年10月末 (最優先で対応中)

【VM-005】 サーバ証明書のSHA-1署名残存

対象: 統合OA基盤内部ポータル (intra.example-bank.local)

CVSS v3.1スコア: 4.3 (Medium)

検出内容: 内部CAが発行したサーバ証明書の署名アルゴリズムがSHA-1のままであった。

改善期限: 2024年12月末 (内部CA証明書更改と同時対応)

発見事項:低リスク

【VL-001】 セキュリティ関連HTTPヘッダの不足

対象: コーポレートサイト、投信・保険販売サイト

検出内容: X-Content-Type-Options、X-Frame-Options、Content-Security-Policy、Strict-Transport-Security ヘッダが一部または全て未設定。

【VL-002】 Cookie属性 (Secure/HttpOnly/SameSite) の設定不備

対象: 投信・保険販売サイト、ローン申込サイト

検出内容: セッションCookieにSecure属性およびSameSite属性が付与されていなかった。

【VL-003】 サーバソフトウェアバージョン情報の露出

対象: 複数システムのHTTPレスポンスヘッダ

検出内容: Server: Apache/2.4.58、X-Powered-By: Servlet/4.0 等のバージョン情報が

レスポンスヘッダに含まれており、攻撃者の情報収集に利用される可能性がある。

【VL-004】ディレクトリリスティングの有効化

対象: コーポレートサイト (/docs/配下)

検出内容: Apache httpd の Options Indexes が有効であり、ディレクトリ一覧が表示される。

【VL-005】不要なHTTPメソッドの許可

対象: 外部向けAPIゲートウェイ

検出内容:

OPTIONS、TRACEメソッドが許可されている。TRACEはXST攻撃に悪用される可能性がある。

【VL-006】DNSゾーン転送の許可

対象: 外部DNSサーバ (ns1.example-bank.co.jp)

検出内容: 任意のホストからのAXFRクエリに応答しており、ゾーン情報の漏洩リスクがある。

【VL-007〜VL-012】その他軽微な指摘

SSL/TLS暗号スイートの優先順位不備、HTTPSリダイレクト未設定 (内部サイト2件)、X-XSS-Protectionヘッダの非推奨設定、HSTS max-age不足 (30日→推奨1年以上)、robots.txtでの管理パス露出、エラーページでのスタックトレース表示 (開発環境)。

改善勧告

検出された脆弱性に対し、以下の優先度別対応スケジュールを勧告する。

【優先度1：即時対応 (対応済み)】

VH-001 Apache Struts脆弱性 → 2024/08/09 対応完了

VH-002 管理画面IP制限 → 2024/08/16 対応完了

【優先度2：1ヶ月以内 (2024年10月末)】

VM-004 開発→本番DB接続経路 →

VPCピアリング設定の見直し、セキュリティグループ最小権限化

【優先度3：3ヶ月以内 (2024年12月末)】

VM-001 TLS 1.0/1.1無効化

VM-002 セッションタイムアウト統一 (全システム15分を推奨)

VM-003 CSRF対策実装

VM-005 SHA-1証明書更新

VL-001〜VL-006 HTTPヘッダ・Cookie属性・その他設定

【優先度4：6ヶ月以内 (2025年3月末)】

VL-007〜VL-012 その他軽微な指摘事項

全件の対応完了をもって、2025年度上期の定期診断に引き継ぐこととする。

フォローアップ

【再診断予定】

高リスク指摘: 改修後の個別再診断を随時実施 (VH-001: 8/12完了、VH-002: 8/20完了)

中リスク指摘: 2024年12月16日〜20日に一括再診断を予定

全体再診断: 2025年4月〜5月 (次年度上期定期診断として実施)

【前年度指摘の改善状況】

2023年度診断で検出された指摘事項（計31件）の改善状況:

対応完了: 28件（90.3%）

対応中: 2件（TLS関連 — 今年度VM-001として継続管理）

受容: 1件（内部テスト環境の軽微な設定 — リスク受容として経営承認済み）

【継続的改善への提言】

1. 脆弱性管理プラットフォーム（Qualys VMDR）の常時監視モードへの移行を推奨
2. CI/CDパイプラインへのSAST/DAST統合（Snyk、Checkmarx等）の導入検討
3. クラウド環境のCSPM（Cloud Security Posture Management）ツール導入
4. 次年度はモバイルアプリ（iOS/Android）の診断を対象に追加することを推奨

以上

2024年9月30日

NRIセキュアテクノロジーズ株式会社

セキュリティアセスメント事業部

主任コンサルタント 佐藤 健一